

Лабораторная работа №2

Исследование уязвимостей ПО и методов их устранения

1 Цель работы

1.1 Изучить основные угрозы безопасности веб-приложений, а также методы защиты от них;

1.2 Научиться применять защитные меры в разработке безопасных веб-приложений.

2 Литература

2.1 Зверева В. П., Сопровождение и обслуживание программного обеспечения компьютерных систем : учебник для студ. учреждений сред. проф. Образования / В. П. Зверева, А. В. Назаров. – М. : Издательский центр «Академия», 2018. – 256 с.

3 Подготовка к работе

3.1 Повторить теоретический материал (см. п.2).

3.2 Изучить описание лабораторной работы.

4 Основное оборудование

4.1 Персональный компьютер.

5 Задание

5.1 Загрузить код уязвимого приложения из репозитория <https://github.com/ReyRom-Edu/VulnerableSite>, выполнить скрипт для создания БД;

5.2 Протестировать SQL-инъекции

5.2.1 Выполнить авторизацию без учетных данных

5.2.2 Получить информацию о структуре БД

5.2.3 Вывести на странице комментариев учетные данные пользователей

5.3 Протестировать XSS-инъекции

5.3.1 Вывести Cookies сессии пользователя

5.3.2 Выполнить инъекцию кода заменяющего гиперссылку пункта меню «Главная» на другую произвольную страницу.

5.4 Протестировать уязвимости авторизации

5.4.1 Опубликовать комментарий от имени несуществующего пользователя.

5.5 Исследовать CSRF-уязвимость

5.5.1 Сменить почту пользователя при помощи CSRF-атаки.

5.6 Исправить код с уязвимостями используя рекомендации из приложения п.9.2

6 Порядок выполнения работы

6.1 Повторить теоретический материал п. 3.1;

6.2 Исследовать уязвимости веб-приложений ПО п. 5.1-5.4;

- 6.3 Ответить на контрольные вопросы п. 8;
- 6.4 Заполнить отчет п. 7.

7 Содержание отчета

- 7.1 Титульный лист;
- 7.2 Цель работы;
- 7.3 Код исправленных модулей п. 5.3;
- 7.4 Ответы на контрольные вопросы п. 6.3;
- 7.5 Вывод по проделанной работе.

8 Контрольные вопросы

- 8.1 Какие методы используются для защиты от sql-инъекций?
- 8.2 Какие методы используются для защиты от xss-инъекций?

9 Приложение

9.1 Уязвимости SQL-инъекций позволяют злоумышленнику выполнять произвольные SQL-запросы через поля ввода с помощью ввода по типу:

```
' ; SQL-команда # или  
' SQL-команда; #
```

Такие запросы позволяют выполнить авторизацию без ввода учетных данных, изменить данные в БД, или вывести произвольные данные из БД на экран.

Для получения информации о структуре БД в MySQL злоумышленник может попытаться получить информацию при помощи UNION-запроса к служебным таблицам для объединения их с выводом уязвимой страницы

```
INFORMATION_SCHEMA.TABLES  
INFORMATION_SCHEMA.COLUMNS
```

Для UNION-запроса необходимо знать количество столбцов в исходном запросе, это можно сделать при помощи ORDER BY с проверкой номера столбца.

Для борьбы с SQL-инъекциями используется экранирование или подготовленные параметризованные запросы.

Этот код демонстрирует уязвимость к XSS, позволяя пользователям вставлять произвольный HTML или JavaScript код в поле комментария и имени пользователя, например

```
<script>alert ()</script>
```

Обратите внимание, что когда вам необходимо записать таким образом текст в кавычках, кавычки необходимо экранировать.

Для борьбы с XSS-инъекциями используется экранирование HTML-символов.

Этот код демонстрирует уязвимость авторизации, позволяя пользователям выполнять операции, на которые у них не должно быть прав.

Для борьбы с данной уязвимостью можно использовать получение данных для данных запросов из сессии вместо прямого указания данных в поле ввода.

Уязвимость CSRF позволяет другим сайтам отправлять запрос к другому сайту и выполнять действия от лица авторизованного пользователя.

Для борьбы с данной уязвимостью можно использовать ограничения политик или специальный CSRF-токен.